אבטחת וב:
מהפרוטוקול ועד לניצול חולשות

Web Security: From the protocol to exploiting vulnerabilities (2026)

Workshop Labs:
https://github.com/m2a2/Research/tree/main/Workshops/2026_Hackeriot

מאור אבוטבול
אביתר גארזי
ליאור יקים

#Who-are-we?

Contact Us

[Maor Abutbul]
Senior Staff Security Researcher
https://il.linkedin.com/in/maor-abutbul

[Eviatar Gerzi]
Sr. Principal Security Researcher
https://il.linkedin.com/in/eviatar-g-25bb6225

[Lior Yakim]
Senior Staff Security Researcher
https://il.linkedin.com/in/lior-yakim-79b100156

CYBERARK®
A PALO ALTO NETWORKS COMPANY

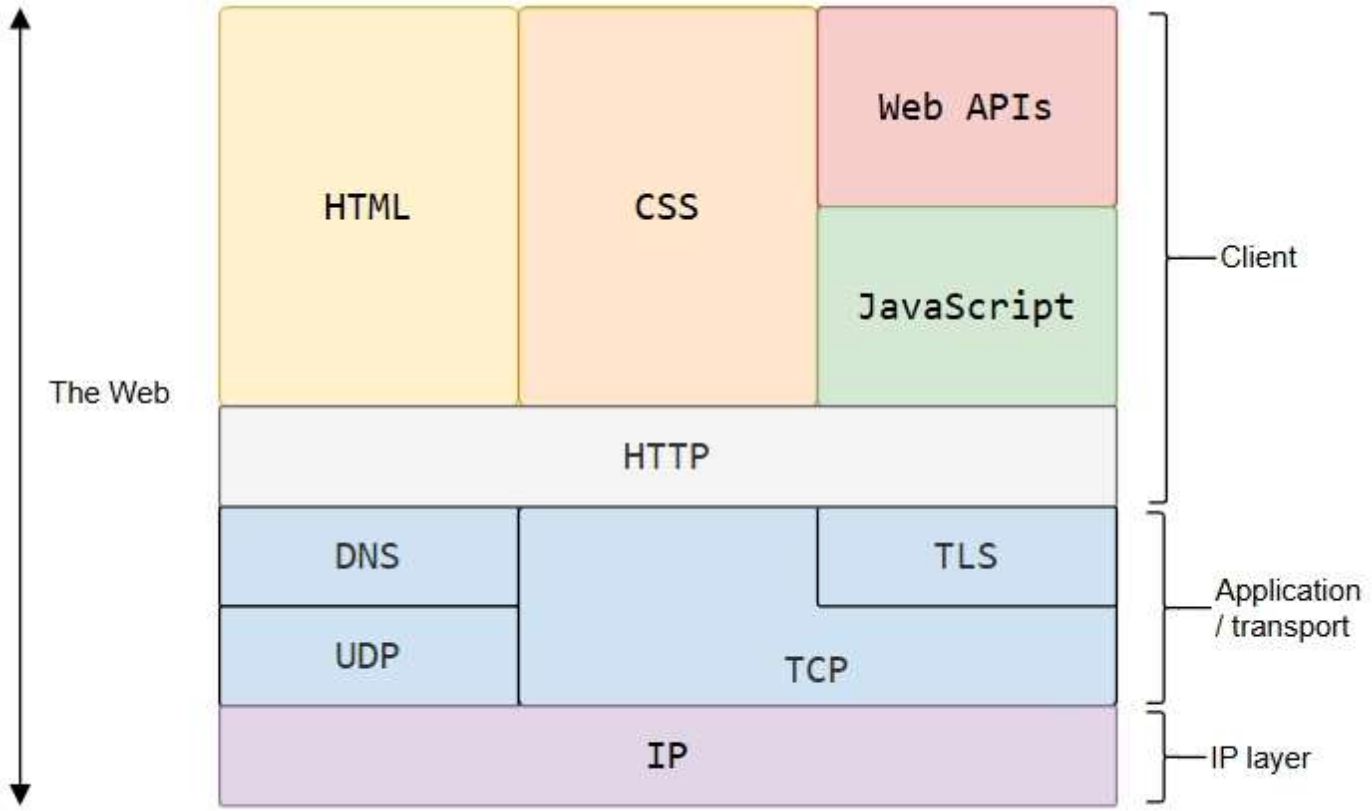
Agenda

- רקע תיאורטי
- כלים לפיתוח ומחקר ווב
- אבטחת מערכות ווב – (Web Security)
  - חולשות נפוצות + מעבדה עצמית
- מקורות תרגול והעשרה + סיכום

Web Technologies – טכנולוגיות ווב (בפיתוח)

Web Technologies - HTML CSS JavaScript

Web Technologies / Layers



HTML - Hypertext Markup Language

HTML is the standard markup language for creating Web pages.

```
<!DOCTYPE html>
<html>
<head>
<title>Page Title</title>
</head>
<body>

<h1>This is a Heading</h1>
<p>This is a paragraph.</p>

</body>
</html>
```

https://www.w3schools.com/html/default.asp

JavaScript

- The world's most popular programming language.
- JavaScript is the programming language of the Web.

```
<!DOCTYPE html>
<html>
<body>

<h2>My First JavaScript</h2>

<button type="button"
onclick="document.getElementById('demo').innerHTML =
Date()">
Click me to display Date and Time.</button>

<p id="demo"></p>

</body>
</html>
```

https://www.w3schools.com/js/default.asp

- הרצת קוד בצד לקוח (דפדפן)

Server-side and client-side technologies

Front-end development refers to the client-side (how a web page looks).

Back-end development refers to the server-side (how a web app works).

Server Side

- PHP, ASP

Web (Server) Frameworks

- Node.js (JavaScript)
- Django (Python)

עיבוד הבקשה נעשה בצד השרת

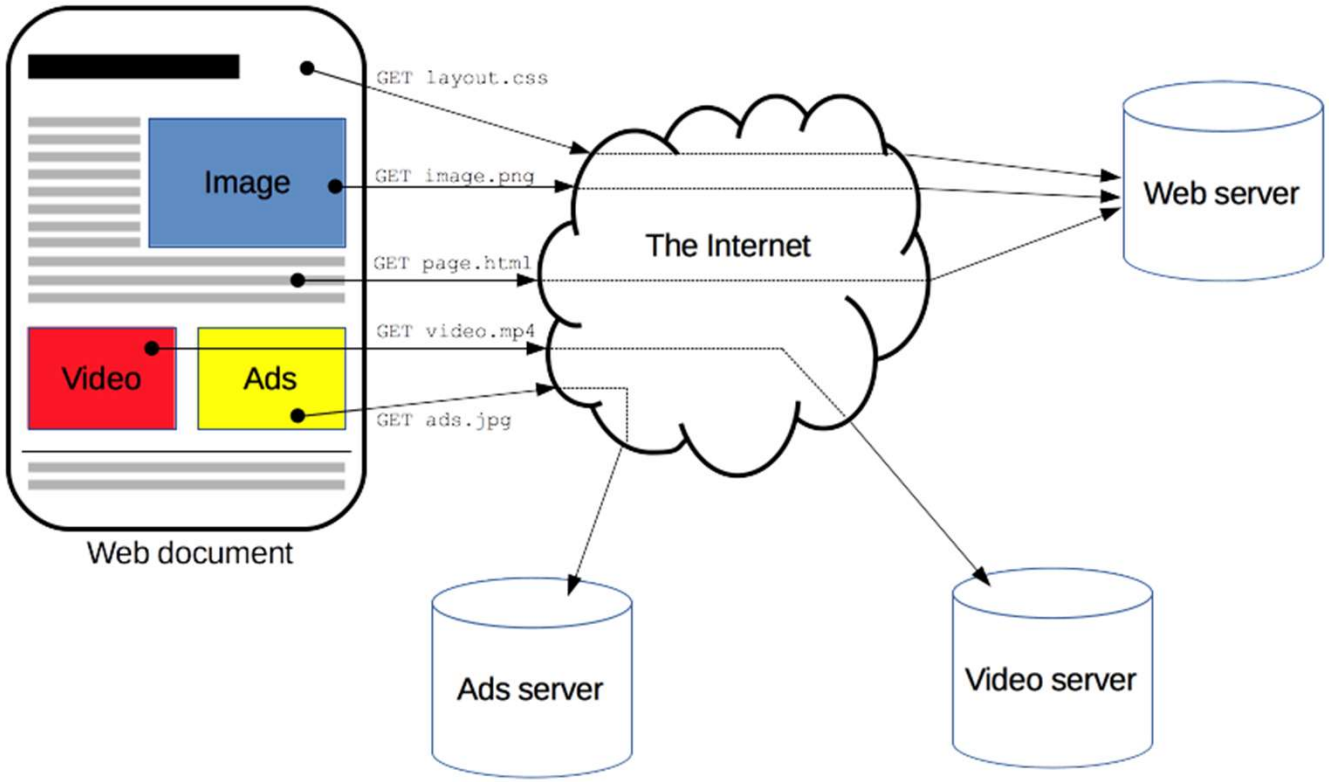
(Static) File-Server vs (Dynamic) Web (REST) API

HTTP Protocol

Hypertext Transfer Protocol (HTTP)

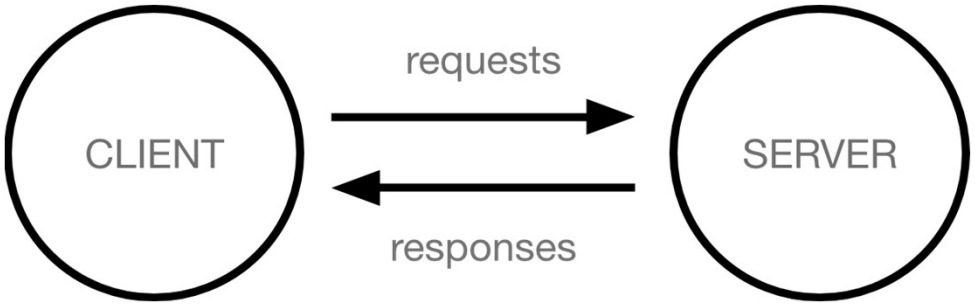
הפרוטוקול שמניע את האינטרנט

HTTP Protocol



HTTP Protocol

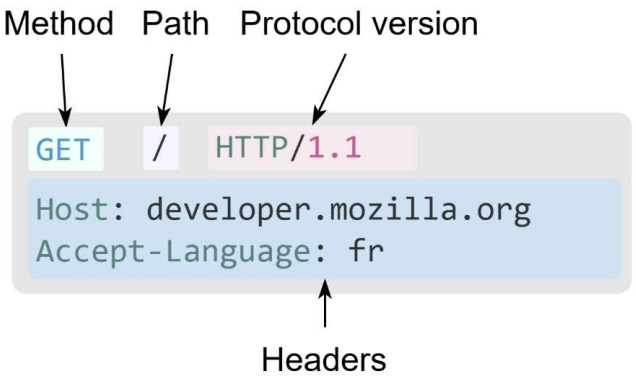
- מודל שרת-לקוח
- Stateless, but not session-less
- הודעות - בקשה תשובה < – > תשובה
- מידע נשלח כ-"טקסט" (ASCII)



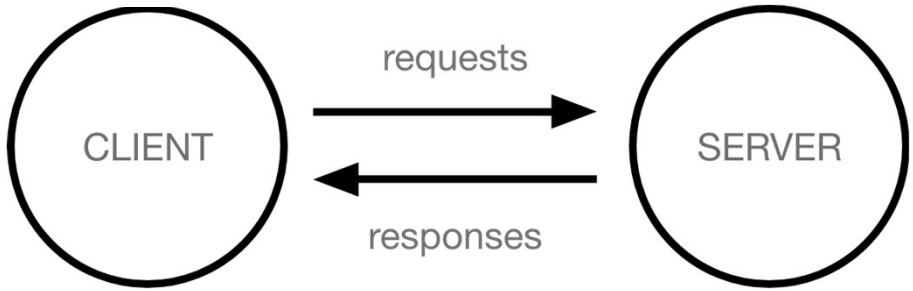
https://developer.mozilla.org/en-US/docs/Web/HTTP/

https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/Overview -

HTTP Protocol Messages

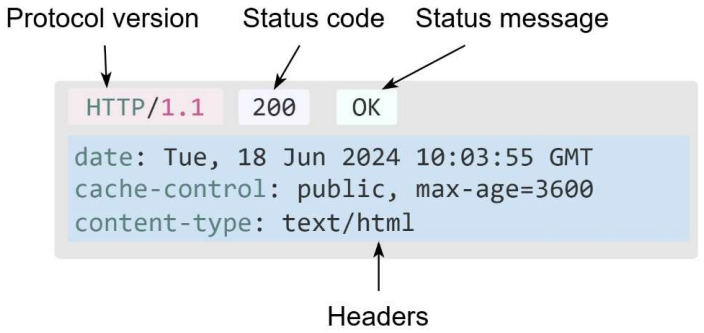


Method
GET
PUT
DELETE
POST



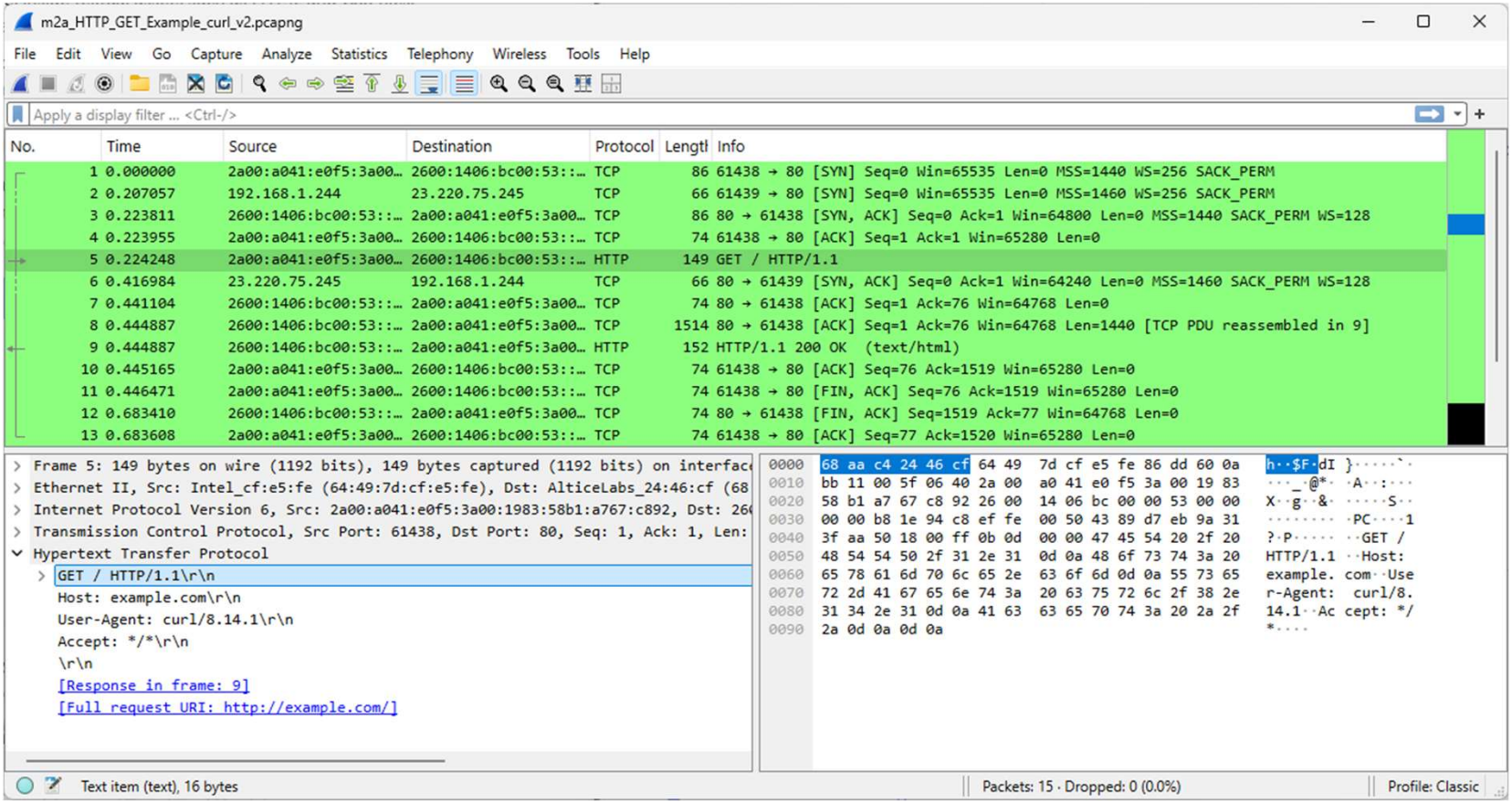
Responses are grouped in five classes:

1. Informational responses (`100` – `199`)
2. Successful responses (`200` – `299`)
3. Redirection messages (`300` – `399`)
4. Client error responses (`400` – `499`)
5. Server error responses (`500` – `599`)



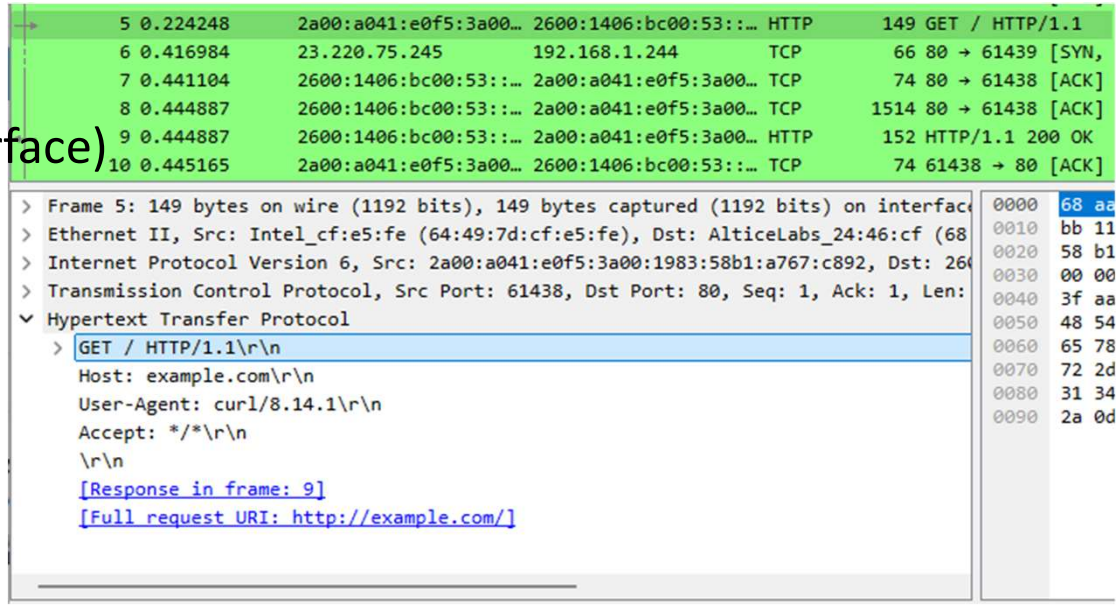
https://developer.mozilla.org/en-US/docs/Web/HTTP/Overview

HTTP Protocol (in Wireshark)



HTTP Protocol (in Wireshark) + Mini Lab

Download - standalone-file-server.zip
Unzip standalone-file-server.zip
(run.sh OR run.cmd)
“python3 -m http.server 8000”
(Optional Wireshark – loopback interface)
Open Browser http://localhost:8000



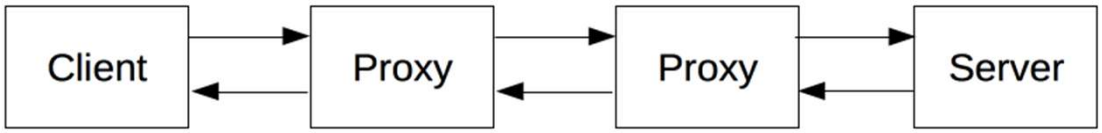
Workshop Labs:
https://github.com/m2a2/Research/tree/main/Workshops/2026_Hackeriot

אבטחת מערכות תקשורת -מבט מלמעלה

(Zoom Out) Network Security in 2 minutes

(דוגמאות ל) רכיבי תקשורת ואבטחה – עבור פרוטוקול HTTP

- רכיבי תקשורת (ואבטחה) ללא "נגיעה" (ניתוח) HTTP
  - Firewall
  - נתב (Router)
  - Network Load Balancer



- רכיבים המנתחים תעבורת HTTP
  - רכיב פרוקסי (Proxy)
  - Application Load Balancer
  - WAF – Web Application Firewall

- Web Server

https://developer.mozilla.org/en-US/docs/Web/HTTP/

כלים לפיתוח ומחקר ווב

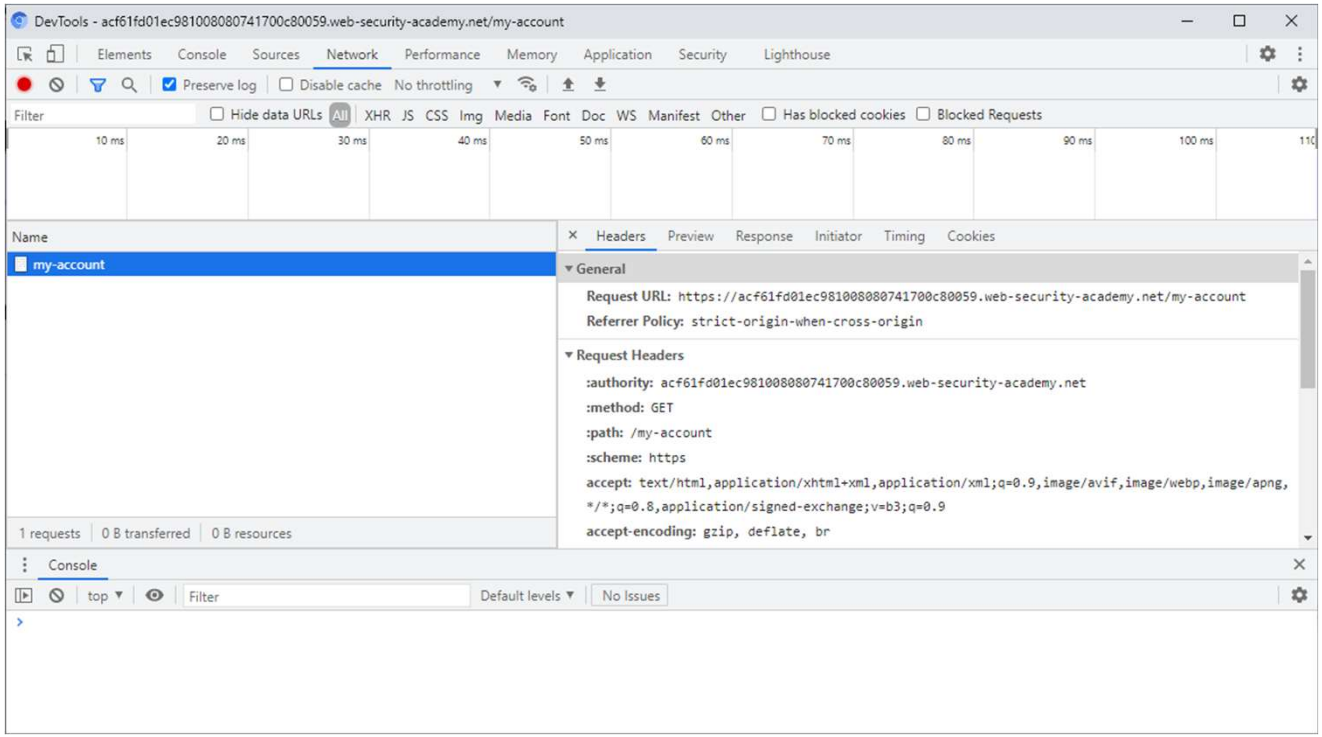
Tools & Demos

Agenda

- רקע תיאורטי
- **כלים לפיתוח ומחקר ווב**
- אבטחת מערכות ווב – (Web Security)
  - חולשות נפוצות + מעבדה עצמית
- מקורות תרגול והעשרה + סיכום

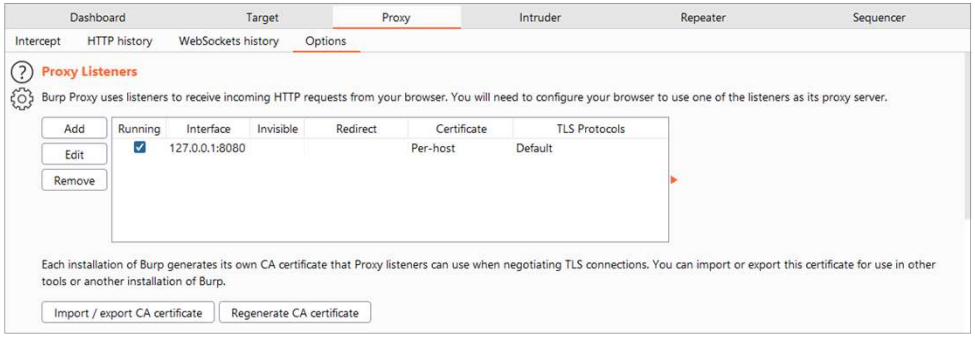
Browser DevTools + Demo

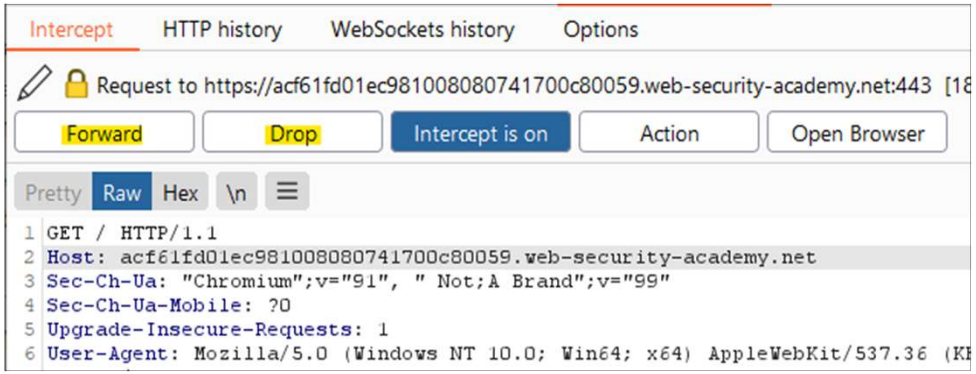
- Elements
- Console
  - Page interaction
- Application
  - Cookies
- Sources
  - Debug
- Network
  - Copy As
  - (fetch + console)



Tools - Burp Suite (Community)

- Host Proxy
- Dashboard
- Target
- Proxy
  - Intercept
  - HTTP History
  - Options

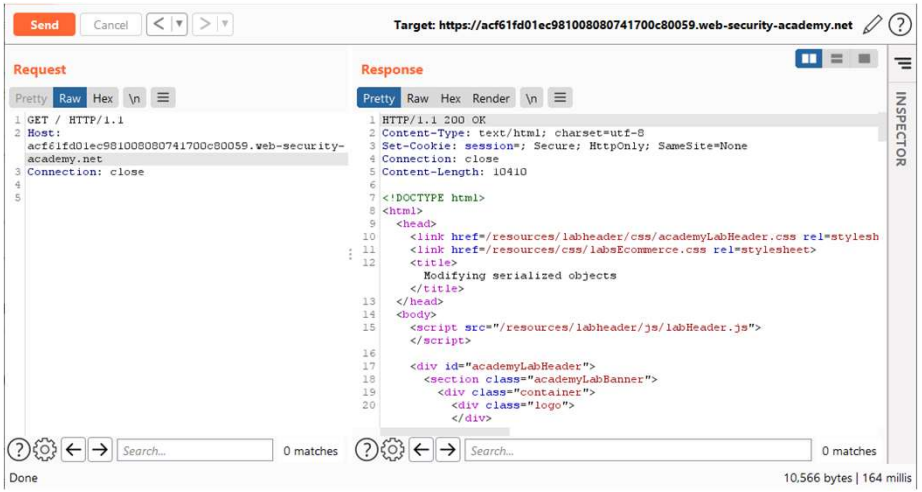


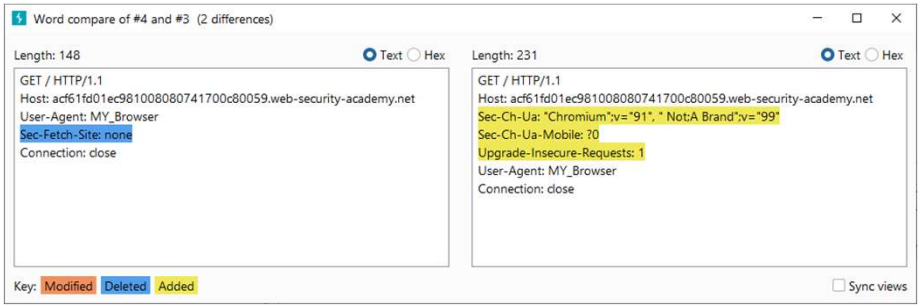


https://portswigger.net/burp/communitydownload

Burp Suite Cont’

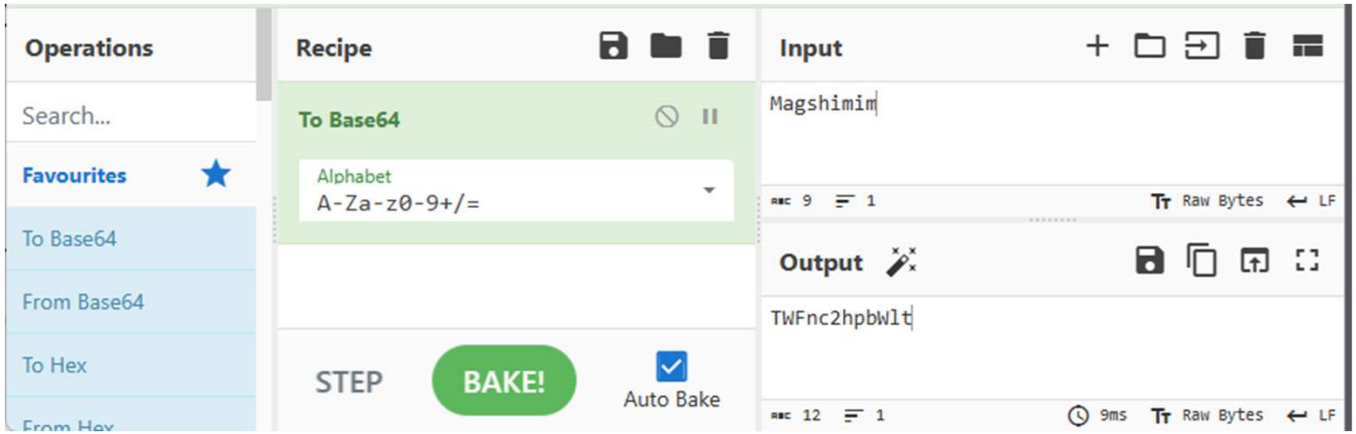
- Repeater (Ctrl + R)
  - עריכה ושליחה ידנית
- Intruder (Ctrl + I)
  - הגדרת "משתנים" וערכי Payload
  - לשליחה אוטומטית
- Decoder
  - פענוח קידודים
- Comparer
  - השוואה בין בקשות
- Extender
  - הורדת וניהול "הרחבות"





Base64 (&URL) Encoding + CyberChef

- קידוד - Base64
  - מיועד להעברת מידע בינארי על גבי ערוץ שתומך בטקסט בלבד (תווי אסקי)
  - משמש לשליחת צרופות (קבצים) בשליחת מיילים (SMTP)



- https://en.wikipedia.org/wiki/Base64
- https://gchq.github.io/CyberChef/#recipe=To_Base64('A-Za-z0-9%2B/%3D')From_Base64('A-Za-z0-9%2B/%3D',true,false/disabled)&input=SGFja2VyaW90

Tools

- Network Analyzer (Wireshark)
  - https://www.wireshark.org/download.html

- Browser Developer Tools (Dev-Tools F12)

- (Host) Proxy Tools
  - Burp Suite - https://portswigger.net/burp/communitydownload
  - ZAP Proxy - https://www.zaproxy.org/
  - Fiddler - https://www.telerik.com/fiddler/fiddler-classic

- CyberChef (Data manipulations / transformations)
  - https://gchq.github.io/CyberChef/

Web Security

Resources - מקורות

Agenda

- רקע תיאורטי
- כלים לפיתוח ומחקר ווב
- **<u>אבטחת מערכות ווב – (Web Security)</u>**
  - חולשות נפוצות + מעבדה עצמית
    - Path Traversal
    - Access Control
    - Authentication
    - Insecure deserialization
- מקורות תרגול והעשרה + סיכום

רגע לפני – אחריות – חוק המחשבים

יש חוק בישראל

- חוק המחשבים, התשנ"ה–1995
  - חוק המחשבים - קישור
- הסבר מתוך קורס של המרכז לחינוך סייבר
  - חוק המחשבים.pdf
- ובכל מקרה
  - חובה להשיג אישור (בכתב!) של בעל הנכס.
  - לשים לב שלא חורגים מהנכסים שהוגדרו לנו.
    - לדוגמא:
    - שרתים משותפים.
    - שירותי אחסון.

Web Security - Resources - מקורות

OWASP - Open Web Application Security Project

- https://owasp.org/

OWASP Top Ten

- https://owasp.org/Top10/

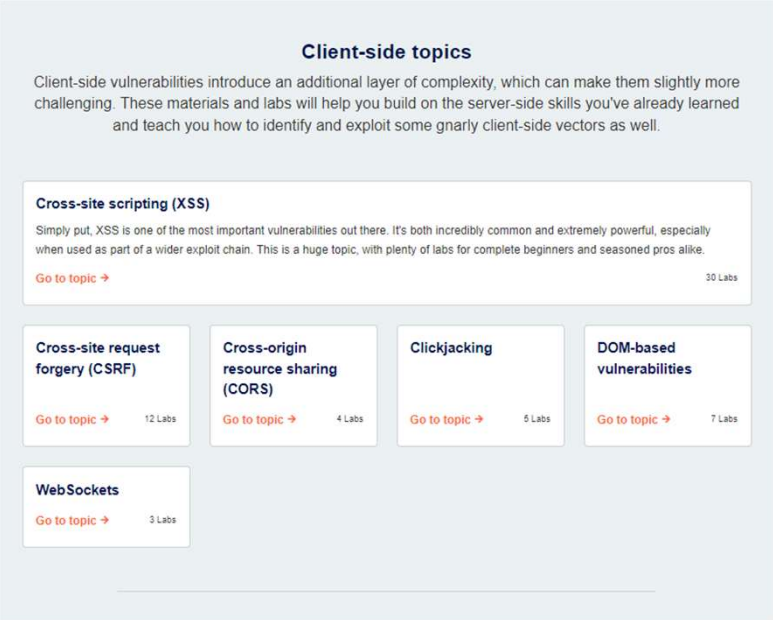
OWASP Web Security Testing Guide

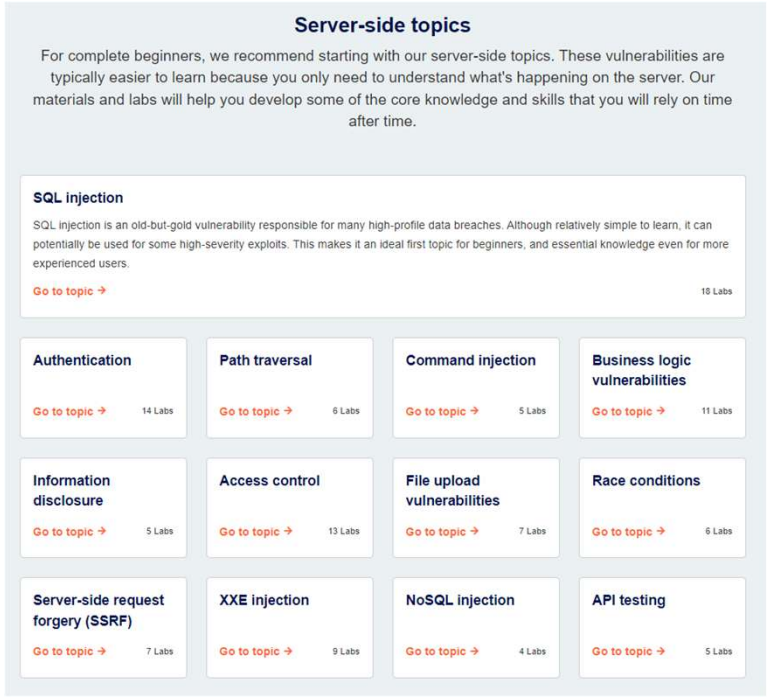
- https://owasp.org/www-project-web-security-testing-guide/v42/

Portswigger - Web Security Academy

- https://portswigger.net/web-security/learning-path

Web Security – Resources - Portswigger - מקורות

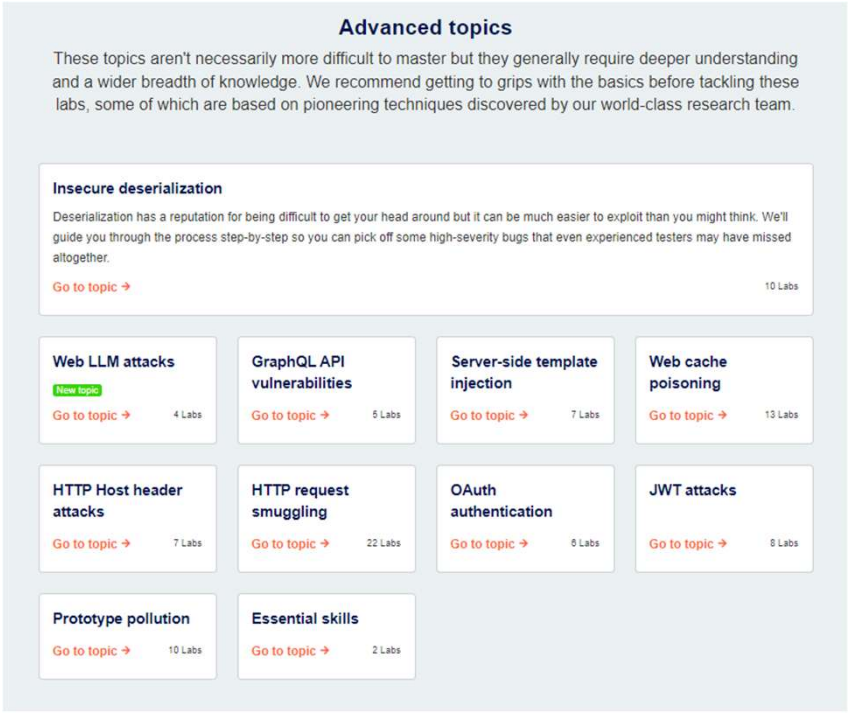




PortSwigger - Web Security Academy

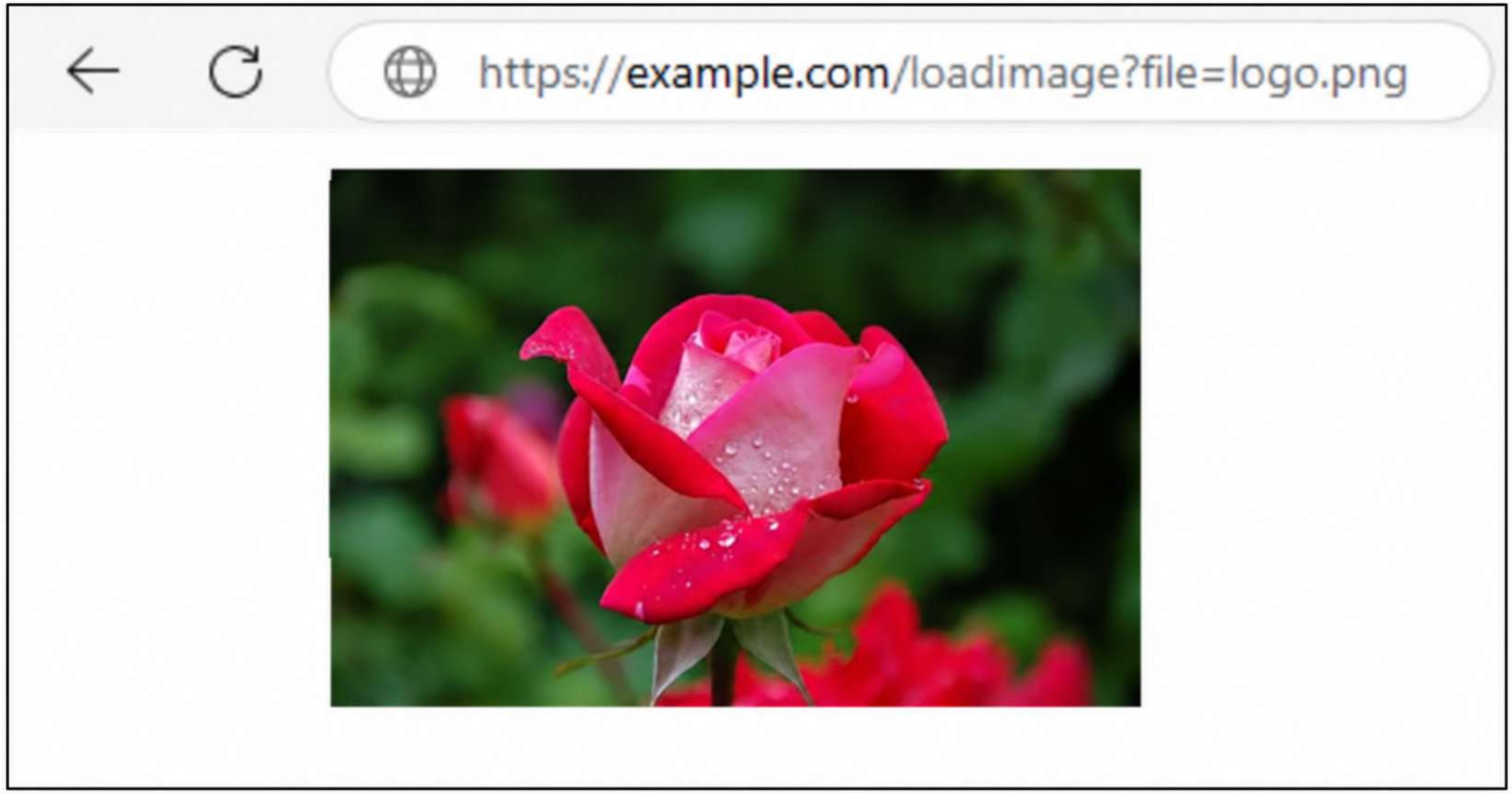
https://portswigger.net/web-security/all-topics

Web Security – Resources - Portswigger - מקורות



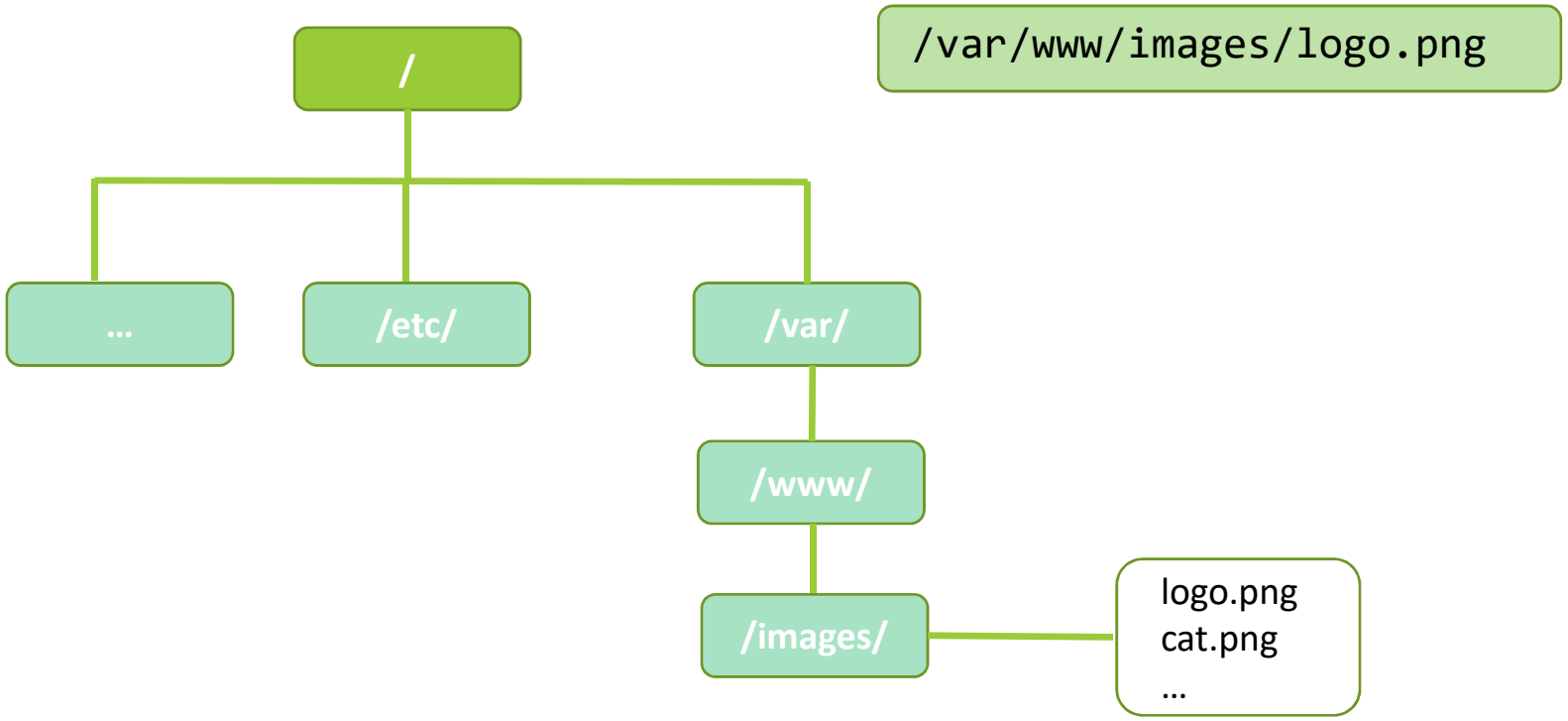
Path\Directory Traversal

Path\Directory Traversal

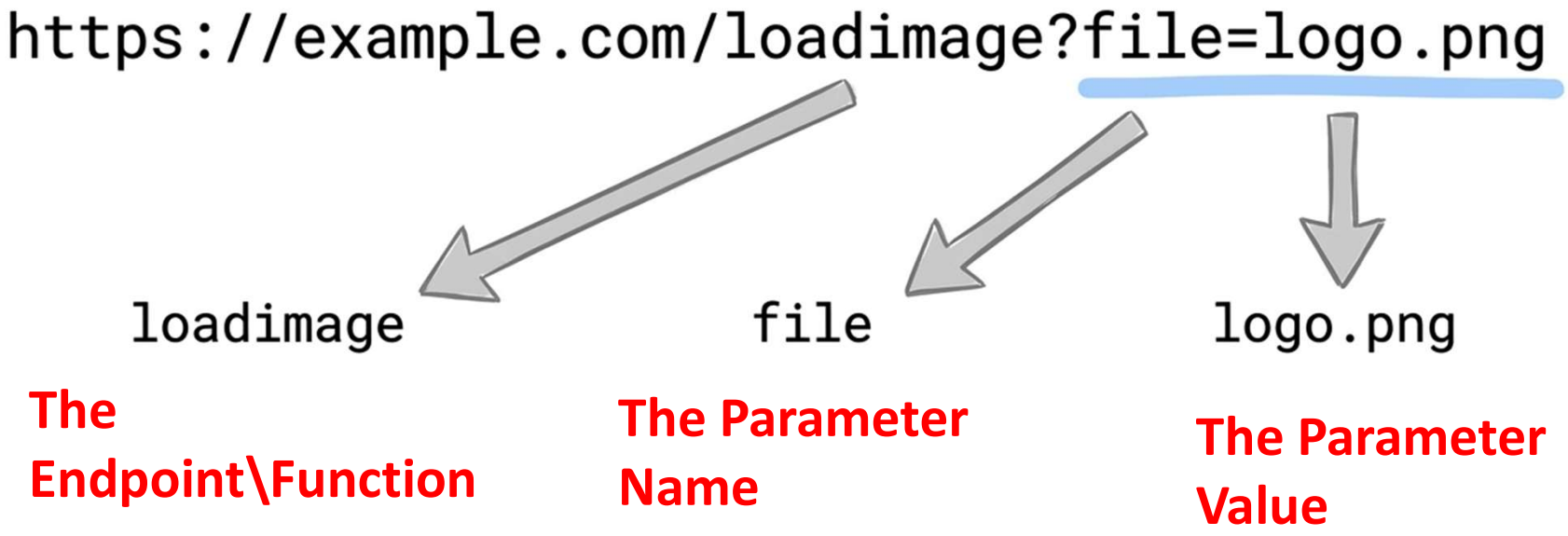


Path\Directory Traversal

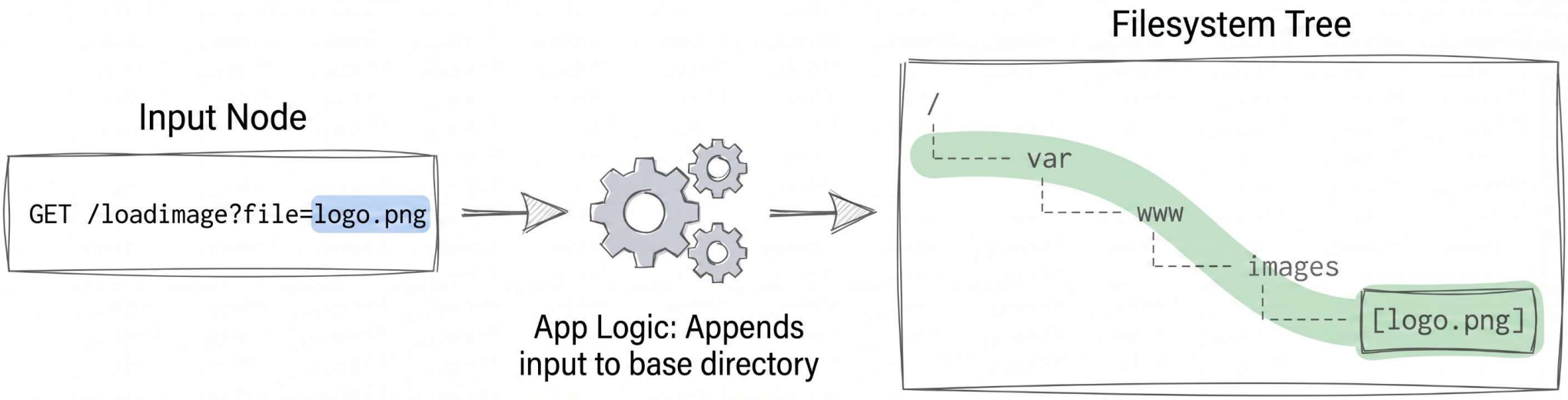
https://example.com/?loadimage=logo.png



Path\Directory Traversal



Path\Directory Traversal



Vulnerable Code

```
base_dir = "/var/www/images/"
file_path = base_dir + user_input
read_file(file_path)
```

Path\Directory Traversal

```
root@Ubuntu:~$ ls .
/home/ubuntu
```

Current directory

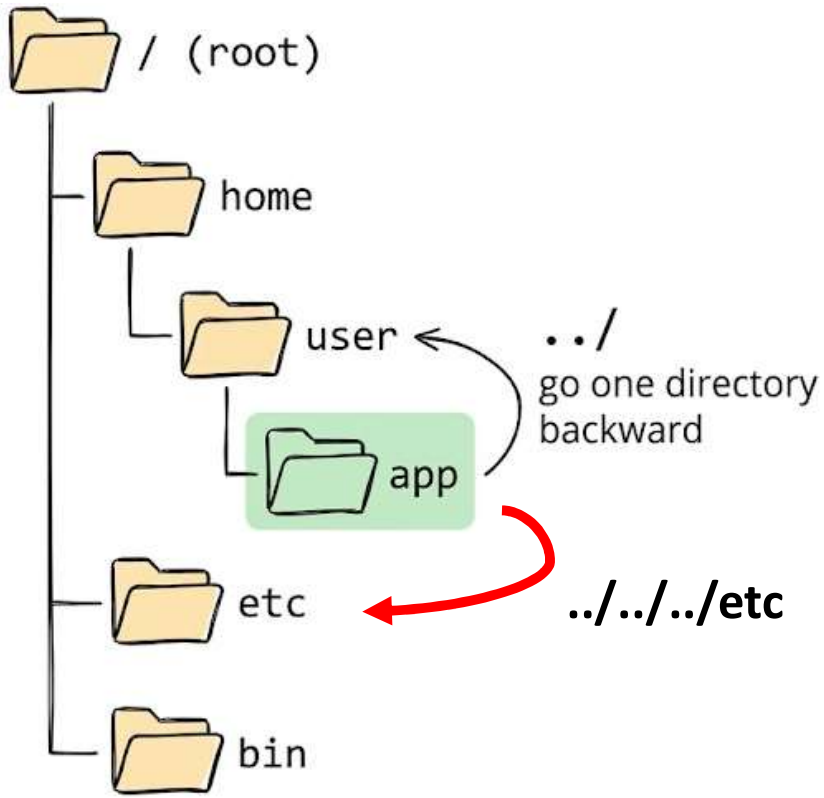
```
root@Ubuntu:~$ ls ..
/home
```

Parent directory

```
root@Ubuntu:~$ ls ../../
/
```

Two parent-directory

Path\Directory Traversal



Path\Directory Traversal

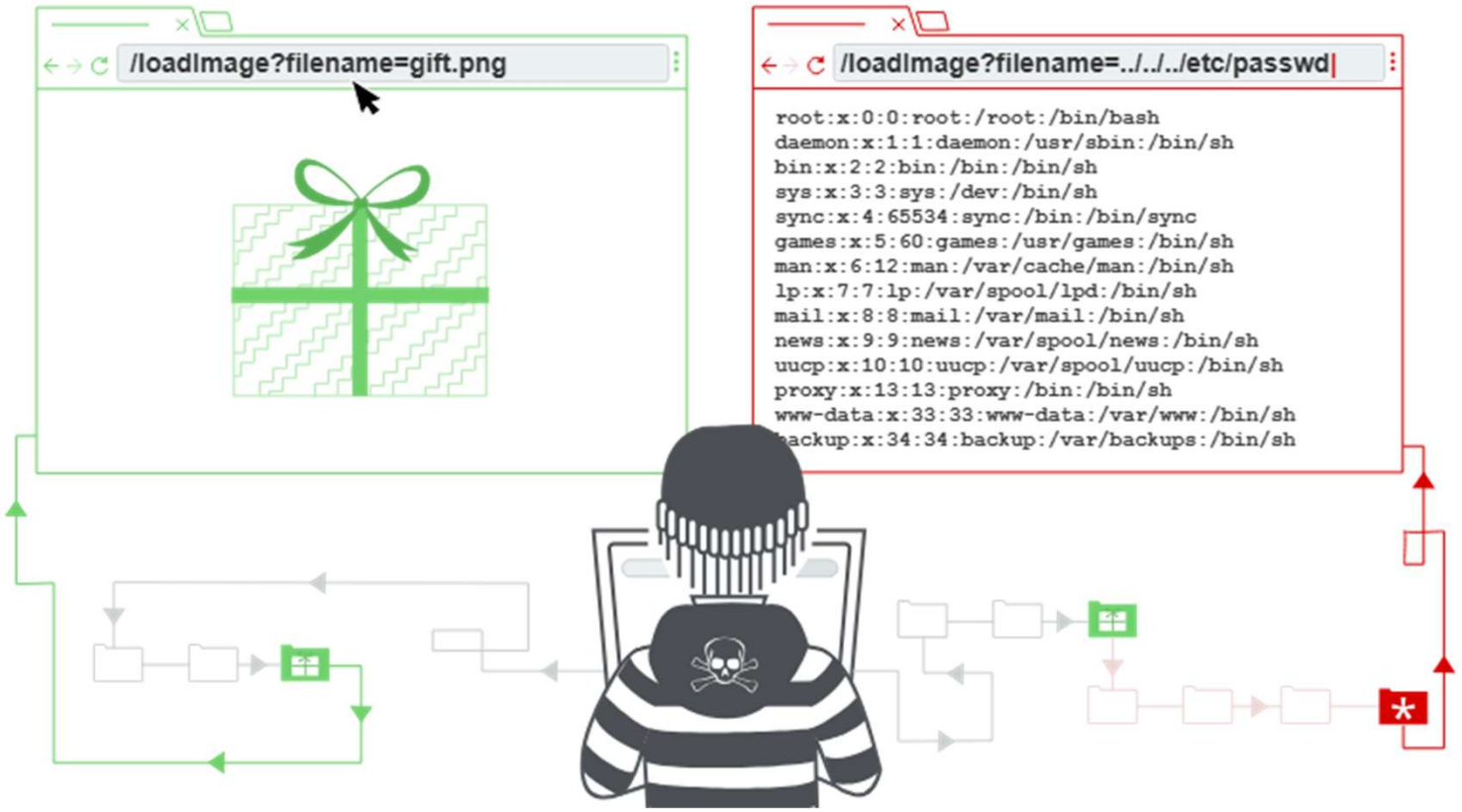
Absolute Path

```
root@Ubuntu:~$ cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
…
```

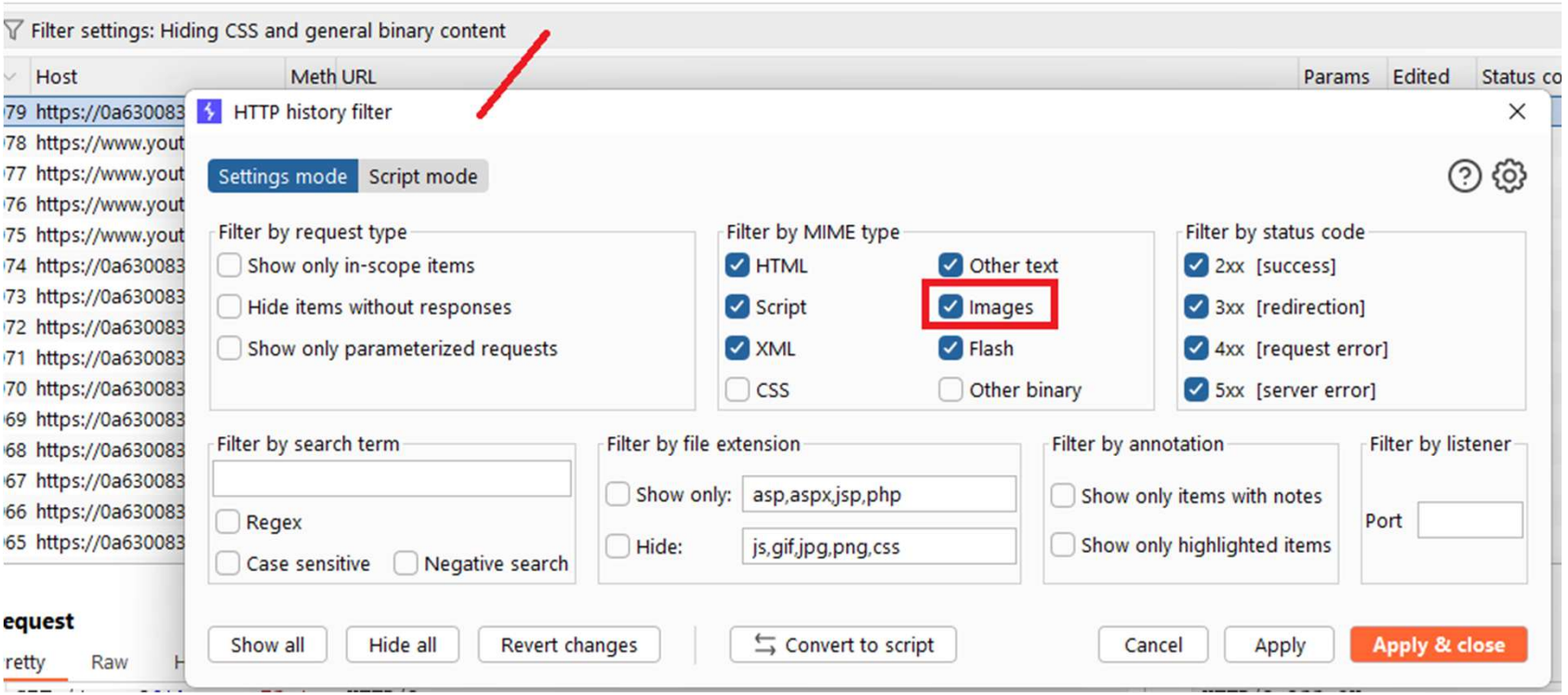
Relative Path

```
root@Ubuntu:~$ cat ../../etc/passwd
root:x:0:0:root:/root:/bin/bash
…
```

Path\Directory Traversal



Path\Directory Traversal



Path\Directory Traversal - Lab

Lab Time - File path traversal, simple case

https://portswigger.net/web-security/file-path-traversal/lab-simple

Workshop Labs:
https://github.com/m2a2/Research/tree/main/Workshops/2026_Hackeriot

Path\Directory Traversal - Lab

Lab Time - File path traversal, traversal sequences blocked with absolute path bypass

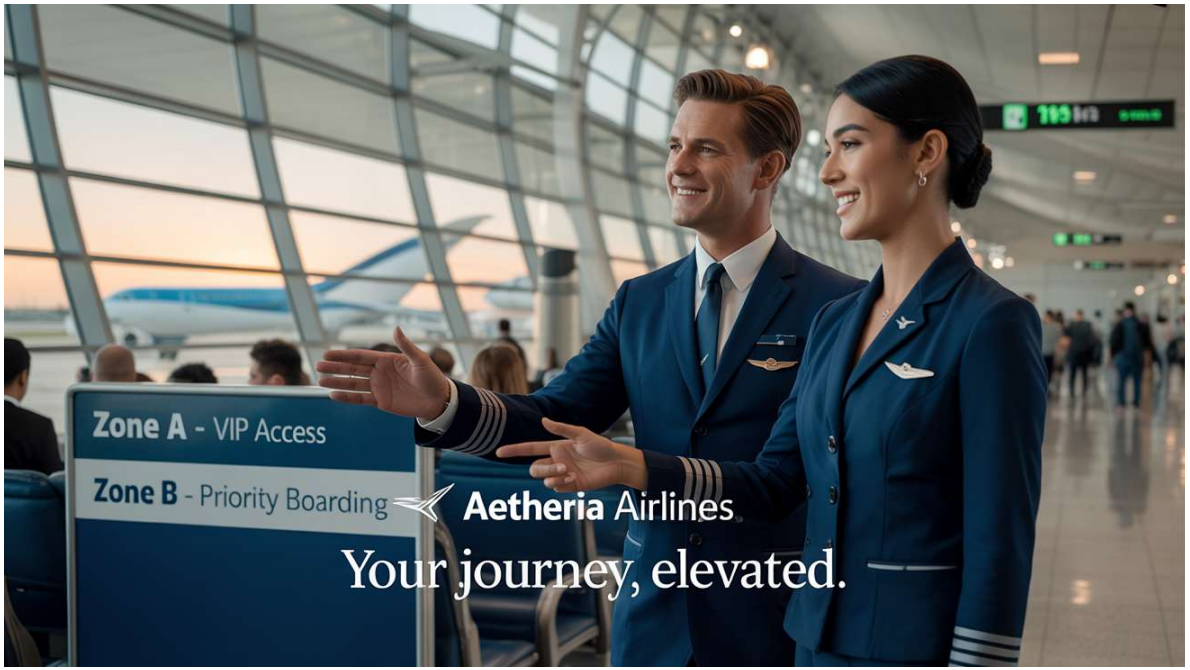
https://portswigger.net/web-security/file-path-traversal/lab-absolute-path-bypass

Workshop Labs:
https://github.com/m2a2/Research/tree/main/Workshops/2026_Hackeriot

Access Control (Authorization)

Access Control (Authorization)

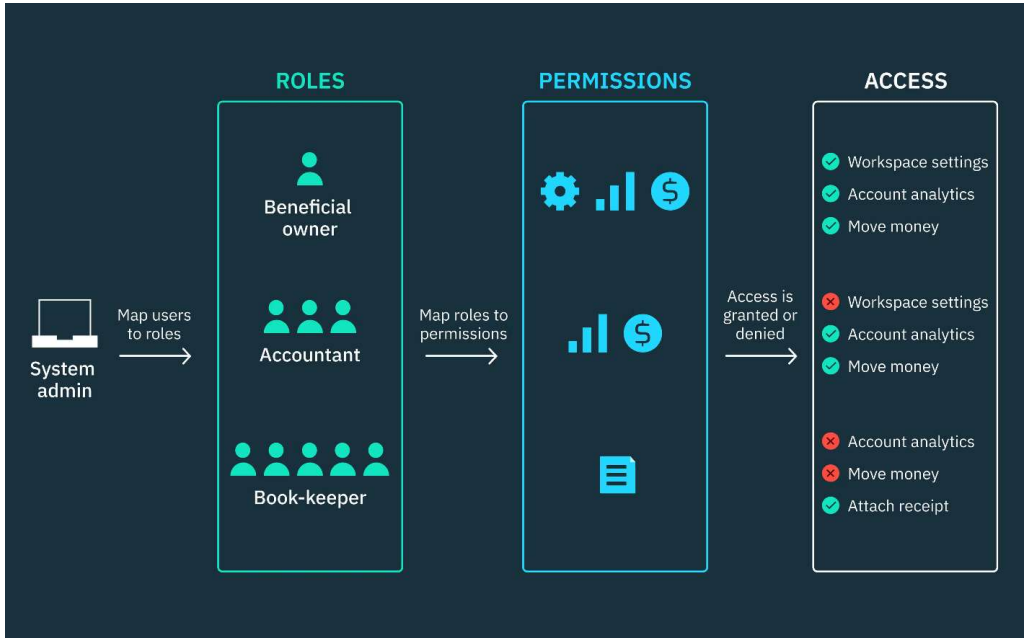
- מימוש הגבלות הקובעות מי רשאי/ת לגשת למשאבי המערכת או לבצע פעולות.



Generated by Ideogram

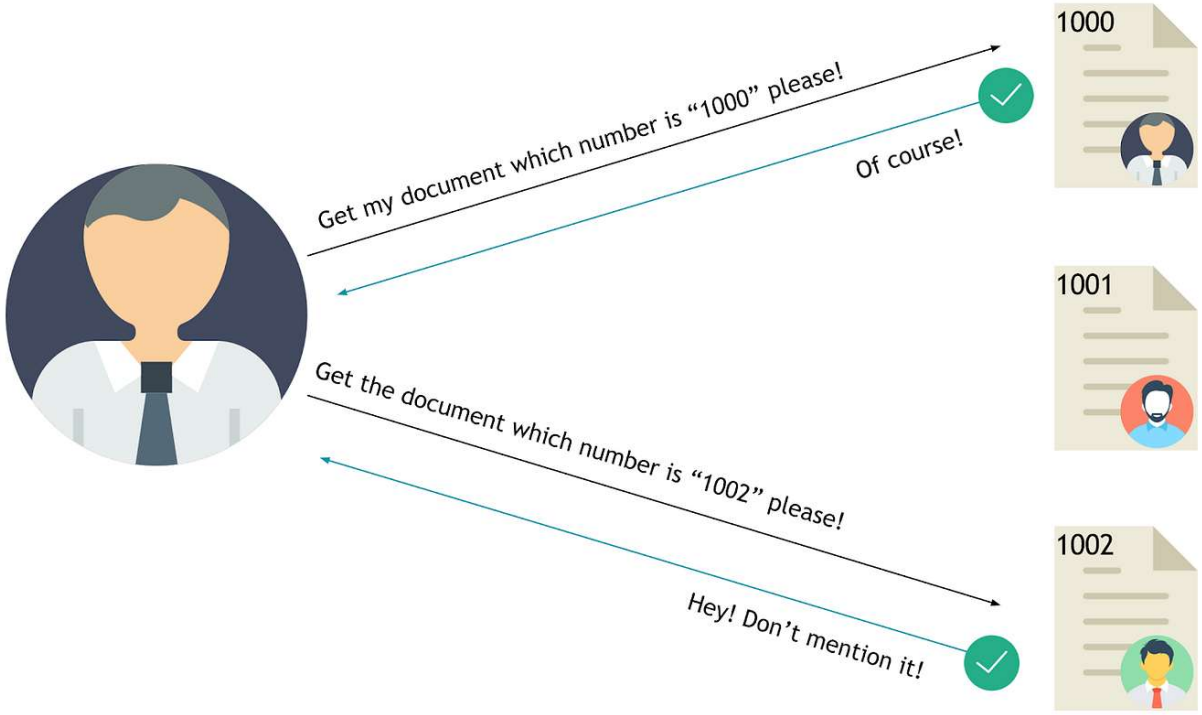
Access Controls Models

- ישנם מספר מודלים מופשטים שניתן ליישם לצורך Access control.
- Role Based Access Control (RBAC) הוא דוגמא נפוצה:



Exploiting Access Controls (Authorization Issues)

Insecure Direct Object Reference (IDOR)



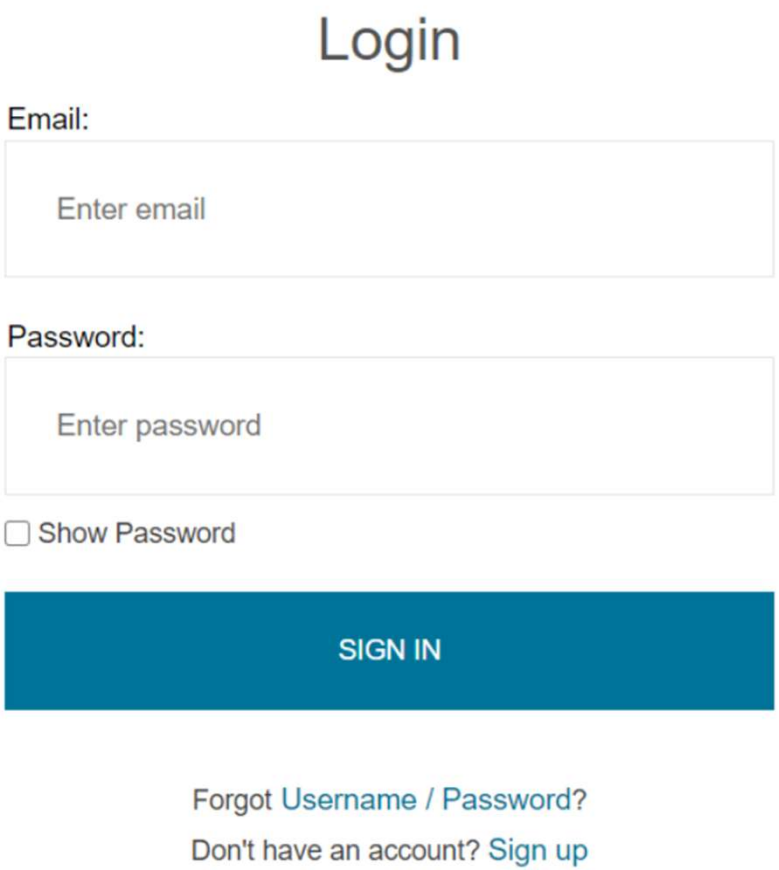
Access Control - Lab

Lab Time – Access Control

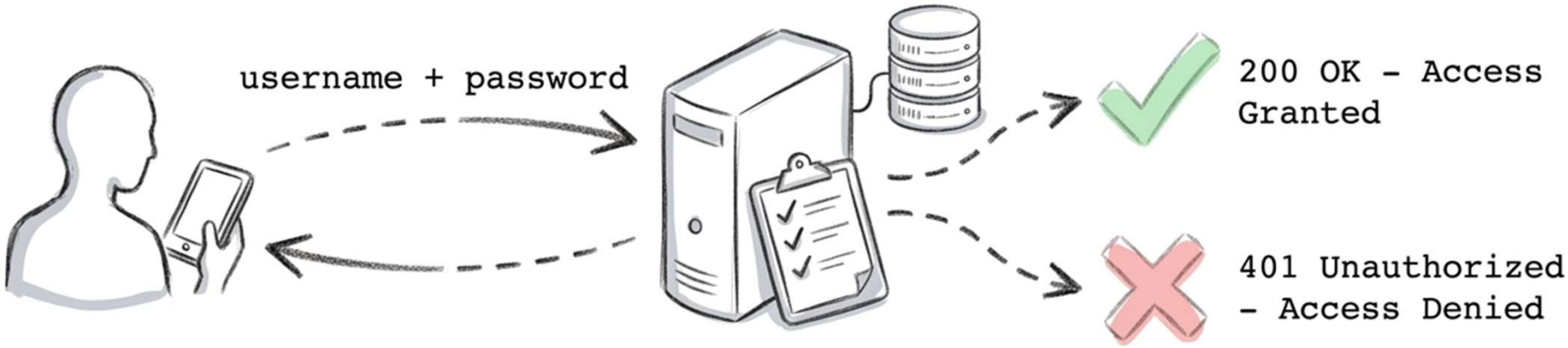
https://portswigger.net/web-security/access-control/lab-unprotected-admin-functionality-with-unpredictable-url

Workshop Labs:
https://github.com/m2a2/Research/tree/main/Workshops/2026_Hackeriot

Authentication


Login
Email:
Enter email
Password:
Enter password
Show Password
SIGN IN
Forgot Username / Password?
Don't have an account? Sign up

The Basic Login Flow



What Happens After Login?

The Login

Upon successful login, the server issues a temporary digital wristband.

The Session

Your browser automatically shows this wristband to the server for every subsequent action.

Authentication

משהו שאתם יודעים

password123

משהו שיש לכם

מכשיר נייד או
מפתח אבטחה

משהו שאתם

טביעת אצבע או
זיהוי פנים

Multi-Factor Authentication (MFA)

Authentication **אימות**

מי אתם?

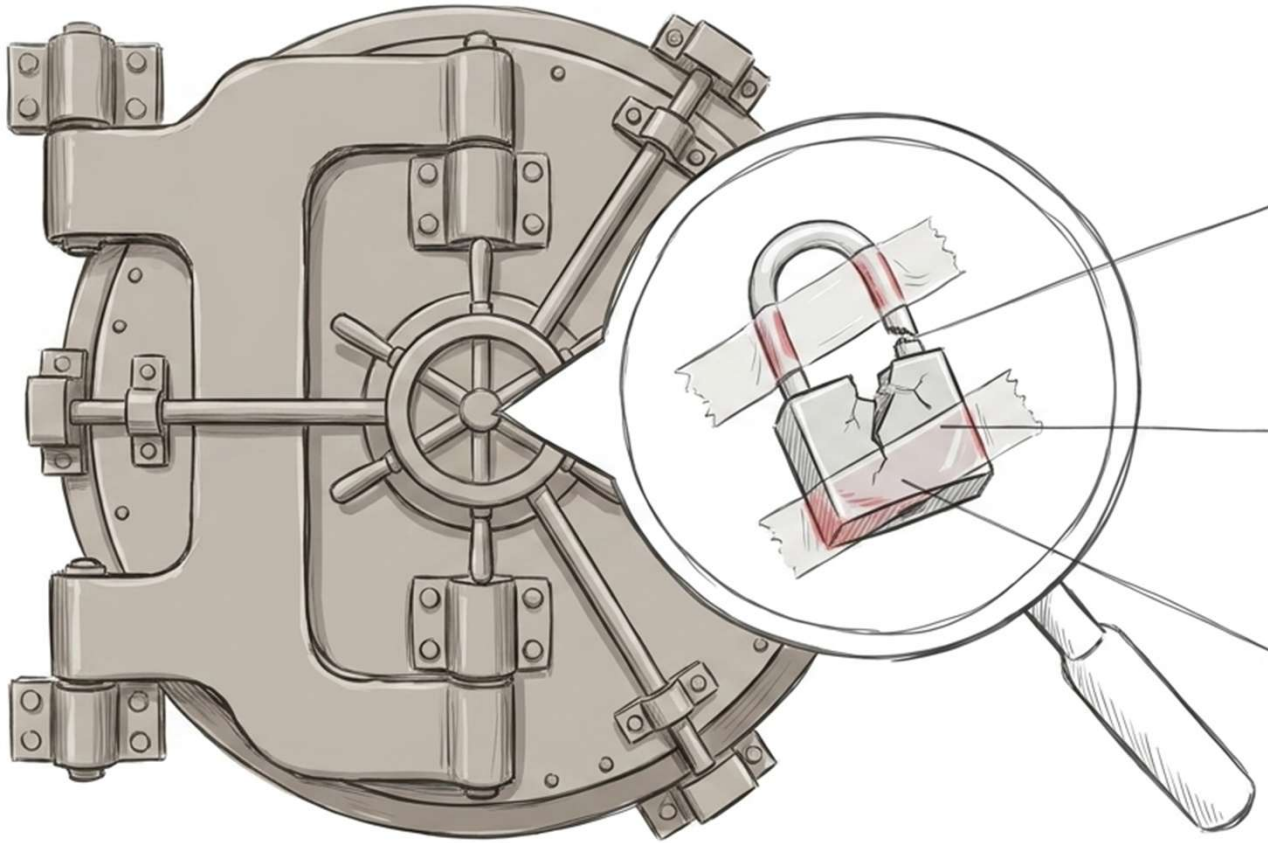
מוודא את זהותכם

Authorization **הרשאה**

מה מותר לכם לעשות?

בודק אם יש לכם גישה

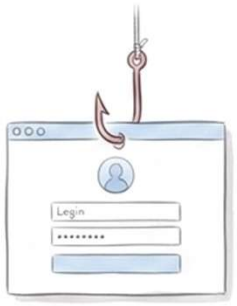
סיסמאות הן לרוב החוליה החלשה



- סיסמאות חלשות וקלות לניחוש
- מיחזור סיסמאות באתרים שונים
- דליפת נתונים מאתרים אחרים

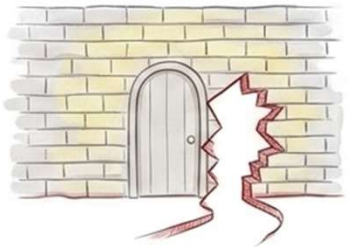
כיצד תוקפים עוקפים את השומר

ניחוש המוני של סיסמאות



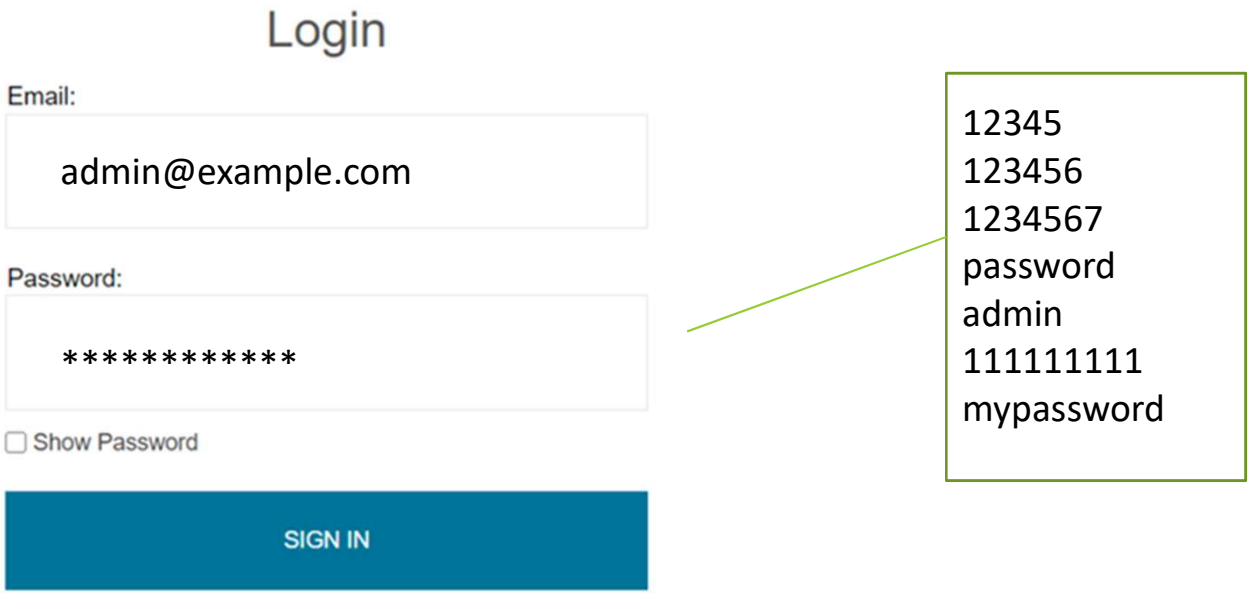
Phishing - התחזות לאתר לגיטימי

גניבת Session

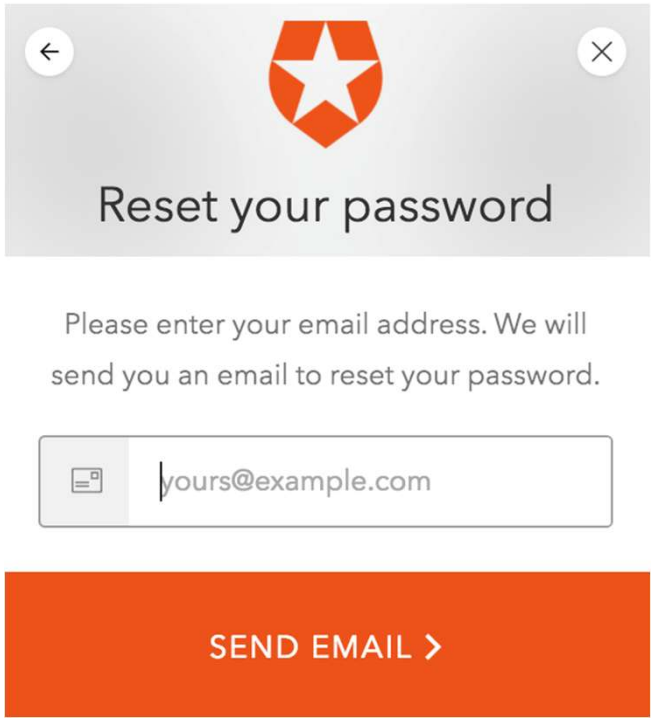


ניצול באגים במנגנון האתר

Authentication – Brute-force



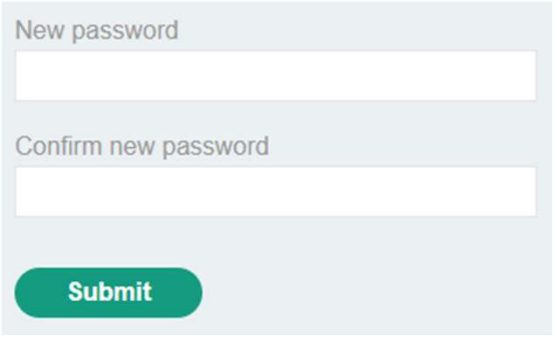
Authentication – Reset Password



Authentication – Reset Password

User clicks ‘Forgot Password’

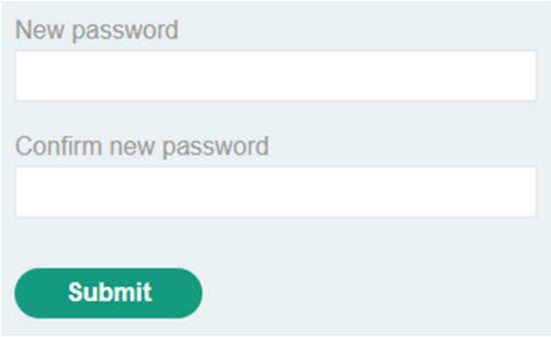
http://vulnerable-website.com/reset-password?**user=victim-user**



Authentication – Reset Password

User clicks ‘Forgot Password’

http://vulnerable-website.com/reset-password?token=a0ba0d1cb3b63d13822572fcff1a241895d893f659164d4cc550b421ebdd48a8



Authentication - Lab

Lab Time - Password reset broken logic

https://portswigger.net/web-security/authentication/other-mechanisms/lab-password-reset-broken-logic

Workshop Labs:
https://github.com/m2a2/Research/tree/main/Workshops/2026_Hackeriot

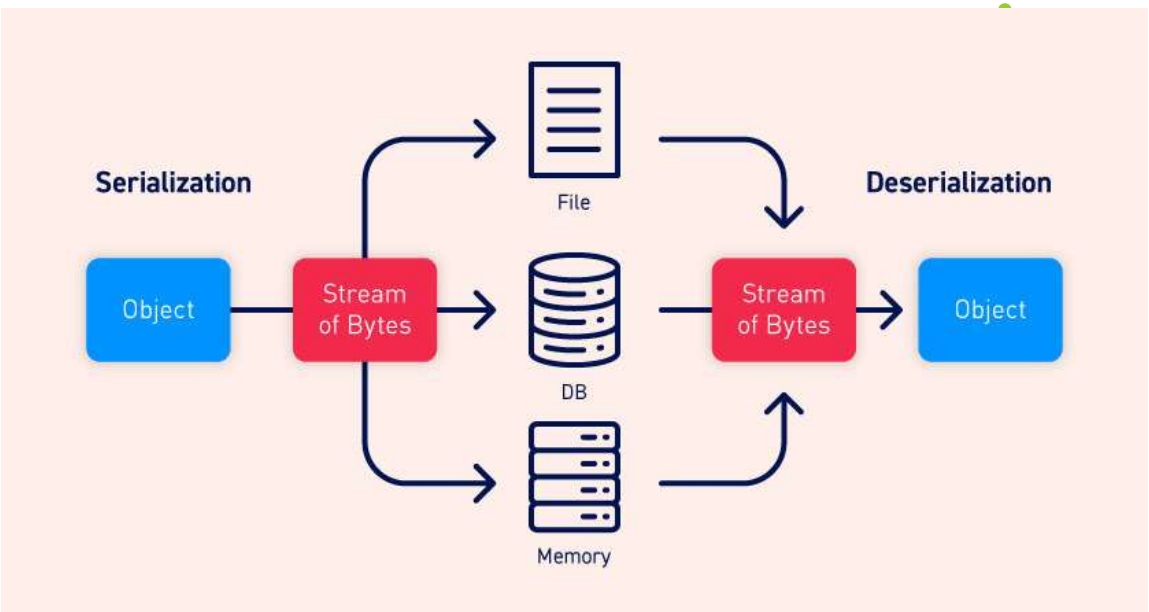
Insecure Deserialization

חולשה נפוצה – פתיחה לא מאובטחת של רצף סדרתי

Insecure Deserialization

- What is serialization?
- Serialization vs deserialization

- מהי סריאליזציה ?
- דיסריאליזציה



Insecure Deserialization - PHP serialize function

serialize

(PHP 4, PHP 5, PHP 7, PHP 8)
serialize — Generates a storable representation of a value

Description

```
serialize(mixed $value): string
```

Generates a storable representation of a value.

This is useful for storing or passing PHP values around without losing their type and structure.

To make the serialized string into a PHP value again, use unserialize().

https://www.php.net/manual/en/function.serialize.php

Insecure Deserialization - PHP unserialize function

unserialize

(PHP 4, PHP 5, PHP 7, PHP 8)
unserialize — Creates a PHP value from a stored representation

Description

```
unserialize(string $data, array $options = []): mixed
```

unserialize() takes a single serialized variable and converts it back into a PHP value.

Warning Do not pass untrusted user input to **unserialize()** regardless of the **options** value of `allowed_classes`. Unserialization can result in code being loaded and executed due to object instantiation and autoloading, and a malicious user may be able to exploit this. Use a safe, standard data interchange format such as JSON (via json_decode() and json_encode()) if you need to pass serialized data to the user.

If you need to unserialize externally-stored serialized data, consider using hash_hmac() for data validation. Make sure data is not modified by anyone but you.

https://www.php.net/manual/en/function.unserialize.php
Demo: https://www.programiz.com/php/online-compiler/

Exploiting Insecure Deserialization Vulnerabilities

PHP serialization format

```
$user->name = "carlos";
$user->isLoggedIn = true;
```

When serialized, this object may look something like this:

```
O:4:"User":2:{s:4:"name":s:6:"carlos"; s:10:"isLoggedIn":b:1;}
```

This can be interpreted as follows:

- `O:4:"User"` - An object with the 4-character class name `"User"`
- `2` - the object has 2 attributes
- `s:4:"name"` - The key of the first attribute is the 4-character string `"name"`
- `s:6:"carlos"` - The value of the first attribute is the 6-character string `"carlos"`
- `s:10:"isLoggedIn"` - The key of the second attribute is the 10-character string `"isLoggedIn"`
- `b:1` - The value of the second attribute is the boolean value `true`

https://portswigger.net/web-security/deserialization/exploiting

- פורמט הסריאליזציה של PHP
- פורמט מבוסס טקסט
- אותיות מייצגות את סוג המשתנה (Data Type)
- מספרים מייצגים אורך של השדה המקודד

Insecure Deserialization

- What is insecure deserialization?

- מהי חולשת "פענוח לא בטוח" ?

- המידע לפיענוח נשלט ע"י המשתמש (או תוקף)

- אף ניתן לשחזר (לייצר) אובייקט מסוג אחר

Exploiting Insecure Deserialization Vulnerabilities

ניצול החולשה

Insecure Deserialization - Exploiting

- How to identify insecure deserialization
  - כיצד נזהה חולשות "פענוח לא בטוח"
  - סטטי (סקר קוד)
  - במידה ויש לנו את קוד המקור
    - נחפש את שמות הפונקציות הרלוונטיות לאותה השפה.
  - דינאמי - (מבדק חדירות)
  - במידה ומכירים את "פורמט הסריאליזציה" של אותה השפה
    - ניתן לזהות ע"י הסתכלות על התוכן שמתקבל מהשרת.
    - כאשר נזהה מידע כזה – ננסה לראות האם אנחנו יכולים לשלוט עליו
- Deserialization - OWASP Cheat Sheet Series
- https://portswigger.net/web-security/deserialization/exploiting

Exploiting Insecure Deserialization - Lab

Lab Time - Insecure Deserialization

https://portswigger.net/web-security/deserialization/exploiting/lab-deserialization-modifying-serialized-objects

Workshop Labs:
https://github.com/m2a2/Research/tree/main/Workshops/2026_Hackeriot

Insecure Deserialization

- How to identify insecure deserialization
  - כיצד נזהה חולשות "פענוח לא בטוח"
  - סטטי (סקר קוד)
  - במידה ויש לנו את קוד המקור
    - נחפש את שמות הפונקציות הרלוונטיות לאותה השפה.
  - דינאמי - (מבדק חדירות)
  - במידה ומכירים את "פורמט הסריאליזציה" של אותה השפה
    - ניתן לזהות ע"י הסתכלות על התוכן שמתקבל מהשרת.
    - כאשר נזהה מידע כזה – ננסה לראות האם אנחנו יכולים לשלוט עליו
- Deserialization - OWASP Cheat Sheet Series
- https://portswigger.net/web-security/deserialization/exploiting

Insecure Deserialization - **הגנות**

- How to prevent insecure deserialization vulnerabilities ?
- כיצד נמנע מתקפות "פענוח לא בטוח" ?

- להימנע ככל הניתן מדיסריאליזציה של תוכן (שנשלט ע"י משתמש)
- יישום בדיקות אמינות (Integrity)
- אכיפת מגבלות סוג אובייקט (מחמירות) בתהליך פתיחה של רצף סדרתי
- בידוד והרצת קוד לפתיחת רצף סדרתי בסביבה בעלת הרשאות נמוכות ככל הניתן

- https://owasp.org/www-pdf-archive/OWASP-Top-10-2017-he.pdf

Insecure Deserialization

- OWASP Top 10 Reference:
  - https://owasp.org/www-project-top-ten/2017/A8_2017-Insecure_Deserialization
- OWASP Deserialization Cheat Sheet
  - https://cheatsheetseries.owasp.org/cheatsheets/Deserialization_Cheat_Sheet.html
- Portswigger - Web Security Academy - Insecure deserialization
  - https://portswigger.net/web-security/deserialization

Insecure Deserialization – Real World Example

CVE’s

Insecure Deserialization – Real World – More CVE's

- https://cve.mitre.org/cgi-bin/cvekey.cgi?keyword=deserialization
- https://www.cvedetails.com/google-search-results.php?q=deserialization
- https://www.cvedetails.com/vulnerability-list/cwe-502/vulnerabilities.html

Resources & Next Steps

Practice, Socialize, To the champions league

Agenda

- רקע תיאורטי
- כלים לפיתוח ומחקר ווב
- אבטחת מערכות ווב – (Web Security)
  - חולשות נפוצות + מעבדה עצמית
    - Path Traversal
    - Access Control
    - Authentication
    - Insecure deserialization
- **<u>מקורות תרגול והעשרה + סיכום</u>**

Web Security – Practice – תרגול עצמי

- **Pico-CTF
  - https://www.picoctf.org/
- Overthewire – Bandit + **Natas
  - https://overthewire.org/wargames/
- **Portswigger - Web Security Academy - Labs
  - https://portswigger.net/web-security/all-labs
  - https://portswigger.net/web-security/learning-path
- OWASP – Practice Systems
  - https://github.com/digininja/DVWA
  - https://github.com/juice-shop/juice-shop
  - https://github.com/WebGoat/WebGoat
- HackTheBox (more system-related, also web challenges)
  - https://www.hackthebox.eu/

Web Security – Social

- OWASP – Meetup & AppSecIL
  - https://www.meetup.com/OWASP-Israel/
- BSidesTLV
  - https://bsidestlv.com/
  - https://bsidestlv.com/ctf/
- Intent Summit (CyberArk)
  - https://intentsummit.org/
- BlueHatIL (Microsoft)
  - https://www.microsoftrnd.co.il/BluehatIL/home
- DEFCON
  - https://defcon.org/index.html
  - https://www.youtube.com/user/DEFCONConference
- BlackHat
  - https://www.blackhat.com/
  - https://www.youtube.com/user/BlackHatOfficialYT

- התנדבות?
- התנדבות!

- הקלטות?
- הקלטות!

CTF & Bug Bounty - תחרויות ותוכניות חיפוש חולשות

- CTF (My two cents)
  - Try Alone
    - Write down what you tried
  - Then (after the event), Read Write-ups!
- CTF Time
  - https://ctftime.org/event/list/upcoming
    - לוח שנה עם תחרויות קרובות
- Bug Bounty - Platforms
  - https://hackerone.com/bug-bounty-programs
  - https://www.bugcrowd.com/bug-bounty-list/
  - https://www.intigriti.com/
- Bug Bounty – Programs for specific companies
  - https://www.guru99.com/bug-bounty-programs.html

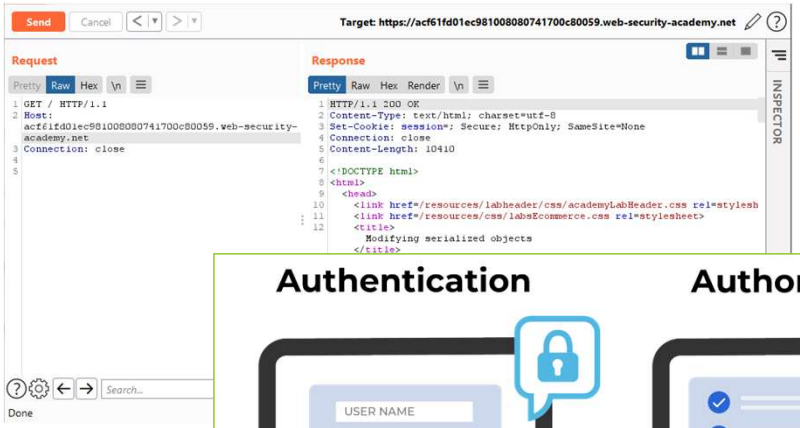
Summary

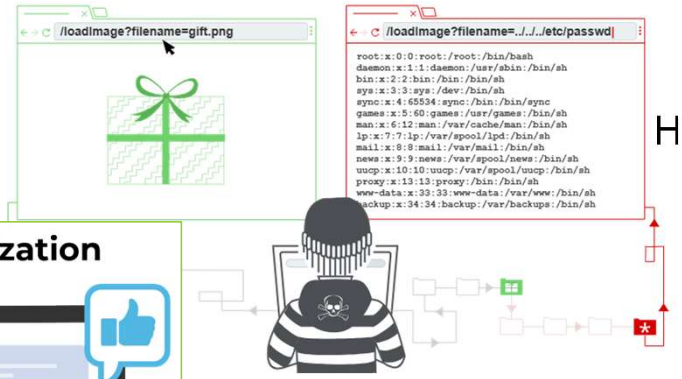
Feedback

https://forms.gle/JTiC1v2jnnoCjde76

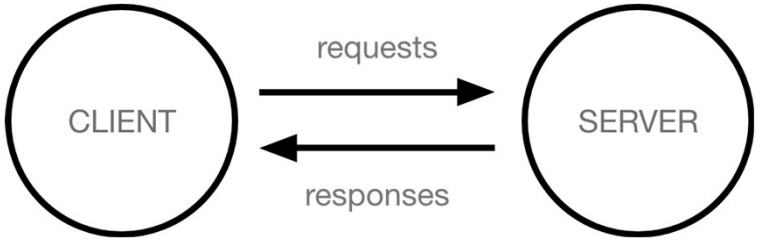
נותרו עוד שני שקפים...

סיכום





- רקע תיאורטי
  - פרוטוקול – HTTP
- כלים שימושיים
- אבטחת וב
  - Path Traversal
  - Access Control (Authorization)
  - הזדהות לעומת בקרת גישה
- מקורות להעשרה ותרגול עצמי



Questions ? (&Thank You!)

Contact Us

[Maor Abutbul]
Senior Staff Security Researcher
https://il.linkedin.com/in/maor-abutbul

[Eviatar Gerzi]
Sr. Principal Security Researcher
https://il.linkedin.com/in/eviatar-g-25bb6225

[Lior Yakim]
Senior Staff Security Researcher
https://il.linkedin.com/in/lior-yakim-79b100156

CYBERARK®
A PALO ALTO NETWORKS COMPANY